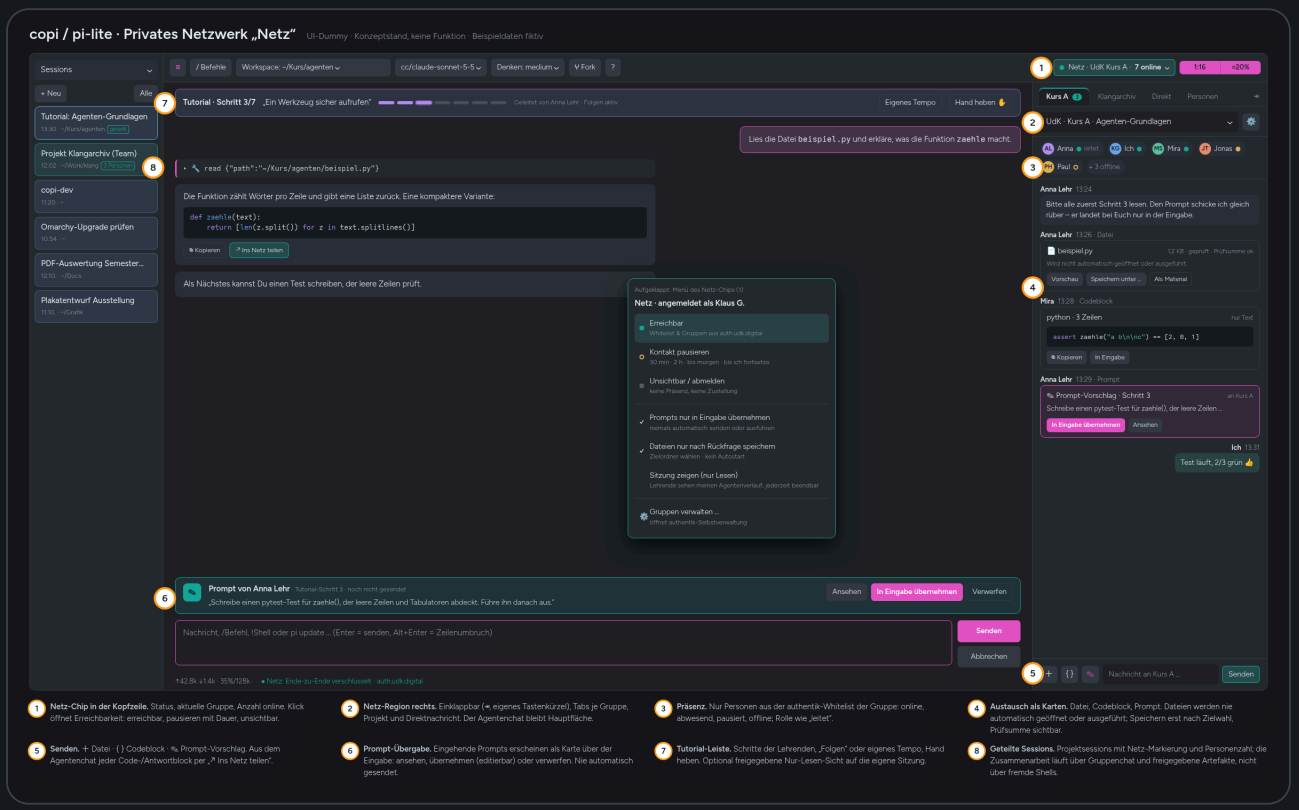
KONZEPT · COPI & PI-LITE

Ein privates Netz für Lehre und Zusammenarbeit

Chatten, Dateien, Codeblöcke und Prompts austauschen, Präsenz sehen, Kontakt steuern – sicher, schlank und mit klaren Empfehlungen für Architektur, Gruppen, Gäste und Datenschutz.



Inhalt

1 Auf einen Blick
2 Ausgangslage und Ziele
3 Der UI-Dummy erklärt
4 Fünf Grundbegriffe
5 Vier Architekturen im Vergleich
6 Peer-to-Peer mit maximaler Sicherheit
7 Gruppen, Rollen und Gäste
8 Lokale Speicherung: Risiken und Schutz
9 Warum Datenschutz trotzdem eine Rolle spielt
10 Empfehlung und Fahrplan
11 Checkliste zum Abhaken
A Begriffe und Bausteine

1 Auf einen Blick

Empfohlen wird ein **schlankes Peer-to-Peer-Netz**, das in copi und pi-lite eingebaut ist. Für UdK-Personen gibt es einen optionalen **„UdK-Ausweis" über authentik**. Ein eigener Matrix-Server ist möglich, für dieses Ziel aber unnötig schwer.

Empfehlung

- **Verbindung:** direkt zwischen den Geräten (P2P, verschlüsselt). Ein eigener Vermittlungsserver (Relay) hilft nur, wenn keine direkte Verbindung möglich ist; er sieht keine Inhalte.
- **Gruppen:** Ende-zu-Ende-Verschlüsselung nach dem Standard MLS. Wer die Gruppe verlässt, kann neue Nachrichten nicht mehr lesen.
- **Identität:** Jedes Gerät hat einen eigenen Schlüssel. authentik bestätigt optional „das ist eine UdK-Person, Gruppe Lehrende".
- **Speicherung:** nur lokal, verschlüsselt, mit selbst gewählten Löschfristen.

Warum nicht einfach Matrix?

Matrix kann alles Nötige, bringt aber einen kompletten Server mit Datenbank, Medienspeicher, Benutzerverwaltung und Betrieb mit. Außerdem kämen eine große Bibliothek in beide Apps und ein zentraler Ort, an dem verschlüsselte Inhalte und Metadaten liegen.

Das P2P-Konzept braucht serverseitig nur zwei kleine, zustandsarme Dienste.

Ihre Frage	Kurzantwort
Eigene Matrix-Instanz?	Machbar (Kap. 5, Variante A), aber nicht die erste Wahl. Wird Matrix gewählt, dann ohne Föderation und mit authentik-Anmeldung.
Schlankere Alternativen ohne Matrix?	Ja: eigenes kleines Relay mit MLS (B), P2P mit iroh (C, empfohlen), oder ein VPN-Netz mit Headscale (D).

P2P, auch ohne authentik, sicher?	Ja. Die Sicherheit entsteht durch Geräteschlüssel, Einmal-Einladungen, gemeinsam geprüfte Sicherheitswörter und MLS. authentik ist dann eine Zusatzbestätigung, keine Voraussetzung (Kap. 6).
Wer legt Gruppen an?	Admins (Kurse über authentik), Lehrende (in der App, durch authentik-Rolle berechtigt) und alle Nutzenden (freie Projekte über Einladungen) (Kap. 7).
Gäste?	Ja, nach Freigabe: Einmal-Einladung, sichtbar markiert, auf eine Gruppe begrenzt, mit Ablaufdatum.
Speicherdauer?	Lokal nach eigenem Ermessen. Die Risiken und Gegenmaßnahmen stehen in Kap. 8.
Ist der UdK-Datenschutz zuständig?	Teilweise ja. Sobald personenbezogene Daten anderer im Lehrbetrieb verarbeitet werden, gilt die DSGVO. Die Begründung und der kleinste sinnvolle Schritt stehen in Kap. 9.

2 Ausgangslage und Ziele

copi (nativ, Rust/egui) und pi-lite (Tauri/Web) sind zwei gleichwertige Oberflächen für den Agenten **pi**. Bisher arbeitet jede Person allein mit ihrem Agenten. Das Netz soll diese Arbeitsplätze verbinden, ohne den Agentenchat zu verdrängen.

Lehren

Ein Tutorial Schritt für Schritt führen, Beispieldateien und fertige Prompts an alle verteilen, Fragen per „Hand heben" sammeln.

Zusammenarbeiten

In Projekten chatten, Codeblöcke und Zwischenstände austauschen, gute Prompts teilen.

Selbst bestimmen

Sehen, wer erreichbar ist, und den eigenen Kontakt jederzeit pausieren. Niemand steuert fremde Rechner.

Leitplanken aus dem bisherigen Projekt

- **Parität:** Jede Funktion entsteht gleichzeitig in copi und pi-lite, idealerweise aus einem gemeinsamen Rust-Baustein `pi-net`.
- **Einwilligung statt Automatik:** Nichts wird ohne ausdrückliche Handlung gesendet, ausgeführt oder an ein KI-Modell weitergegeben. Das gilt auch für eingehende Prompts.
- **Originale bleiben unverändert:** Empfangene Dateien landen nicht von selbst im Arbeitsordner.
- **Schlank bleiben:** wenig Serverbetrieb, wenige zusätzliche Abhängigkeiten, keine neue Daueraufgabe für Admins.

> **Didaktischer Hinweis: Was „Prompt-Injektion im positiven Sinn" hier heißt**
>
> Gemeint ist die bewusste **Übergabe eines fertigen Prompts** von Lehrenden an Lernende. Eine Lehrende formuliert die Aufgabe einmal sorgfältig, und alle erhalten sie als Vorschlag in ihrer Eingabezeile. Entscheidend ist, dass die empfangende Person den Prompt **sieht, ändern kann und selbst abschickt**.
>
> Damit unterscheidet sich die Funktion grundlegend von einer echten (schädlichen) Prompt-Injektion, bei der Anweisungen unbemerkt in den Agenten gelangen.

3 Der UI-Dummy erklärt

Der Entwurf zeigt, wie sich das Netz in die bestehende Oberfläche einfügt. Die Bedienung folgt drei Regeln:

1. **Der Agentenchat bleibt in der Mitte.** Das Netz ist eine einklappbare Region am rechten Rand.
2. **Ein eigenes Farbsignal:** Alles, was über das Netz kommt oder dorthin geht, ist türkis. Dadurch ist es nicht mit Agentenausgaben zu verwechseln.
3. **Austausch als Karten:** Dateien, Codeblöcke und Prompts erscheinen als Karten mit Aktionen, nie als ausführbarer Fließtext.

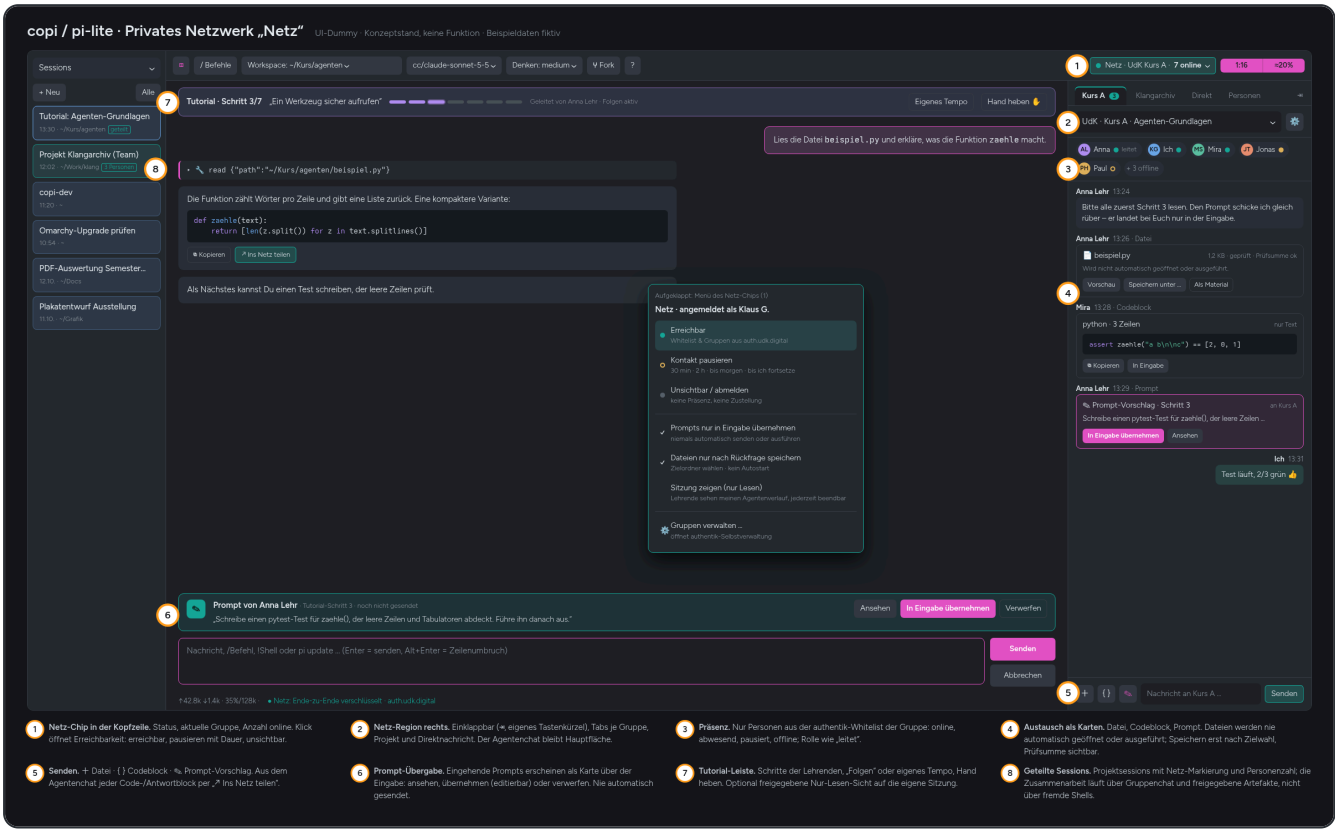


Abb. 1 – Hauptfenster mit Netz-Region, Tutorial-Leiste, eingehendem Prompt und geöffnetem Erreichbarkeitsmenü (Beispieldaten fiktiv).

Nr.	Element	Funktion und Begründung
1	Netz-Chip in der Kopfzeile	Zeigt Status, aktive Gruppe und Personen online. Das Menü steuert die Erreichbarkeit: erreichbar, pausieren für 30 min, 2 h, bis morgen oder bis auf Weiteres, unsichtbar. Die Erreichbarkeit soll mit einem Klick änderbar sein, ohne Einstellungsdialog.
2	Netz-Region rechts	Reiter für Kurse, Projekte und Direktgespräche, mit Ungelesen-Zähler. Lässt sich per Tastenkürzel einklappen.
3	Präsenz	Online, abwesend, pausiert oder offline, dazu eine Rolle wie „leitet“. Es erscheinen nur Gruppenmitglieder, keine globale Personensuche.
4	Karten	Datei mit Prüfsumme und „Speichern unter …“; Codeblock zum Kopieren oder Übernehmen; Prompt zum Übernehmen in die Eingabe.
5	Senden	+ Datei · { } Codeblock · ✎ Prompt. Im Agentenchat hat jeder Block zusätzlich „↗ Ins Netz teilen“.

6	Prompt-Übergabe	Ein eingehender Prompt erscheint als Karte über der Eingabe: ansehen, übernehmen (bleibt editierbar) oder verwerfen. Er wird nie automatisch gesendet.
7	Tutorial-Leiste	Zeigt Schritt x/y. Teilnehmende wählen „Folgen“ oder „Eigenes Tempo“ und können die Hand heben.
8	Geteilte Sessions	Markierung und Personenzahl in der Session-Liste. Projektsessions bleiben lokale Agentensitzungen; geteilt werden nur Chat und Artefakte.

4 Fünf Grundbegriffe

Die Architekturentscheidung lässt sich mit fünf Begriffen erklären. Wer diese Seite kennt, kann die Varianten in Kapitel 5 selbst bewerten.

① Identität ≠ Transport

Identität beantwortet die Frage „Wer bist du, und darfst du hinein?“. Das kann authentik leisten. **Transport** beantwortet „Wie kommt die Nachricht an?“. Dafür braucht es Server, Relays oder direkte Verbindungen. authentik ist ein Ausweisamt, keine Post.

② Ende-zu-Ende-Verschlüsselung (E2EE)

Nur die Geräte der Gruppenmitglieder können Inhalte lesen. Server oder Relays sehen höchstens verschlüsselte Pakete und Metadaten: wer, wann, wie groß. Gegen Metadaten hilft E2EE nicht, dagegen hilft nur Sparsamkeit im Design.

③ Peer-to-Peer (P2P) und Relay

Bei P2P sprechen Geräte direkt miteinander. Firewalls und Uni-WLANs verhindern das oft. Ein **Relay** leitet dann verschlüsselte Pakete weiter, ohne sie lesen zu können. P2P braucht also meist trotzdem einen kleinen Hilfsserver, aber keinen, der Inhalte speichert.

④ MLS – verschlüsselte Gruppen

Messaging Layer Security (IETF-Standard RFC 9420) verwaltet einen gemeinsamen Schlüssel für Gruppen mit wenigen bis vielen Mitgliedern. Bei jedem Ein- oder Austritt wird der Schlüssel erneuert:

- Neue Mitglieder lesen nicht rückwirkend mit.
- Entfernte Mitglieder lesen nichts Neues mehr.

Mit **OpenMLS** gibt es eine Rust-Umsetzung.

⑤ Sicherheitswörter (Schlüsselprüfung)

Zwei Personen vergleichen persönlich oder am Telefon eine kurze Wortfolge, die aus ihren Geräteschlüsseln berechnet wird. Stimmt sie überein, sitzt garantiert niemand dazwischen. Das ist die stärkste und zugleich einfachste Schutzmaßnahme gegen gefälschte Kontakte.

5 Vier Architekturen im Vergleich

Alle vier Varianten erfüllen die Grundfunktionen. Sie unterscheiden sich darin, **wie viel Server** nötig ist, **wie groß die Apps** werden und **wer welche Daten sieht**.

A Eigene Matrix-Instanz

Neuer Homeserver unter UdK-Domain (z. B. Synapse oder ein schlankerer Rust-Server der Conduit-Familie), Anmeldung per OIDC über authentik, Föderation abgeschaltet. Die Apps nutzen `matrix-rust-sdk`.

+ ausgereift: E2EE, Präsenz, Dateien, Spaces, Offline-Zustellung; Element als Ersatz-Client.
− dauerhafter Serverbetrieb mit Datenbank, Medienspeicher, Updates und Backups; große Bibliothek in beiden Apps; zentraler Ort für verschlüsselte Inhalte und Metadaten; das Matrix-Rechtemodell passt nur indirekt zu authentik-Gruppen.

B Eigenes kleines Relay + MLS

Ein einziger kleiner Dienst (WebSocket, SQLite) prüft authentik-Tokens und leitet verschlüsselte MLS-Nachrichten weiter. Für Offline-Empfänger hält er sie mit Ablaufzeit zwischen.

+ schlank, volle Kontrolle, gute Offline-Zustellung, einfache Anbindung an authentik.
− eigenes Protokoll muss gebaut, getestet und geprüft werden; ohne Server keine Kommunikation; Gäste brauchen ein authentik-Konto oder einen Sonderweg.

C P2P mit iroh + MLS · empfohlen

Geräte verbinden sich direkt über **iroh** (Rust, QUIC, Lochstanzen durch NAT, verschlüsselt, Ausweichen über ein Relay). Gruppen laufen über OpenMLS, Dateien über inhaltsadressierte Blobs. authentik stellt optional einen signierten „UdK-Ausweis" aus.

+ kein zentraler Datenspeicher, Relay sieht nur verschlüsselte Pakete, gleicher Rust-Kern für beide Apps, funktioniert auch ohne authentik (freie Projekte, Gäste), im LAN sogar ganz ohne Internet.
− Nachrichten an Offline-Personen brauchen einen kleinen Zwischenspeicher oder warten; Mitglieder sehen sich bei direkter Verbindung gegenseitig die IP-Adressen (abschaltbar: nur über Relay).

D VPN-Netz: Headscale/WireGuard

Ein selbst betriebener Headscale-Server (Anmeldung über authentik) bildet ein privates WireGuard-Netz. Die Apps sprechen darin direkt miteinander.

+ sehr robuste, geprüfte Netzschicht; Gruppenregeln als Zugriffsregeln (ACL).
− verlangt einen zusätzlichen VPN-Client und Systemrechte auf jedem Gerät; öffnet ein ganzes Netz statt nur einer App; Gäste umständlich; Gruppen-E2EE und Chat müssen trotzdem selbst gebaut werden.

Kriterium	A Matrix	B Relay+MLS	C P2P iroh	D Headscale
Serverbetrieb	hoch	gering	minimal[1]	mittel
Zusatzgröße der Apps	groß	klein	mittel	klein + VPN
Inhalte zentral gespeichert	ja, verschlüsselt	kurz, verschlüsselt	nein	nein
Metadaten zentral	viele	einige	wenige	Verbindungen
Offline-Zustellung	ja	ja	mit Postfach[2]	nein
Ohne authentik nutzbar	kaum	kaum	ja	eingeschränkt

Gäste	Konto nötig	Sonderweg	Einladung	umständlich
Eigenentwicklung	wenig	viel	mittel	viel

[1] Ein selbst betriebenes iroh-Relay und ein kleiner Ausweis-Dienst, beide ohne Inhaltsspeicher. [2] Optionales „Postfach“: ein kleiner Dienst, der verschlüsselte Nachrichten für Offline-Personen begrenzt aufbewahrt.

Einordnung

C erfüllt die Wünsche „schlank“, „P2P“, „auch ohne authentik“ und „maximale Sicherheit“ am besten. **A** lohnt sich nur, wenn Offline-Zustellung, Mehrgeräte-Komfort und ein fertiger Ersatz-Client wichtiger sind als Schlankheit. **B** und **D** sind Zwischenlösungen ohne klaren Vorteil gegenüber C.

6 Peer-to-Peer mit maximaler Sicherheit

Auch ohne zentrale Instanz kann ein P2P-Netz sehr sicher sein. Die Sicherheit entsteht aus mehreren Schichten, die sich gegenseitig absichern.

Gerät	Jedes Gerät erzeugt einen eigenen Schlüssel (Ed25519) und legt ihn im System-Schlüsselbund ab. Der Schlüssel verlässt das Gerät nie und wird nicht zentral registriert.
Einladung	Zutritt nur per Einmal-Einladung (Link oder QR): an eine Gruppe gebunden, gültig für eine Person, mit Ablaufdatum, widerrufbar. Sie enthält das Beitrittsrecht, keinen Inhalt.
Prüfung	Nach dem Beitritt vergleichen beide Seiten sechs Sicherheitswörter. Ändert sich später ein Schlüssel (z. B. durch ein neues Gerät), zeigt die App einen Hinweis und setzt die Person auf „nicht geprüft“.
Verbindung	iroh baut verschlüsselte QUIC-Verbindungen auf, die an den Geräteschlüssel gebunden sind (TLS 1.3). Das Relay sieht nur verschlüsselte Pakete. Es sollte selbst betrieben werden, damit keine Drittanbieter-Infrastruktur nötig ist.
Gruppe	MLS erneuert den Gruppenschlüssel bei jedem Ein- und Austritt. Entfernte Personen lesen nichts Neues mehr, und alte Schlüssel werden verworfen (Vorwärtssicherheit).
Inhalt	Dateien mit Prüfsumme und Größenlimit, ohne Ausführungsrecht gespeichert. Prompts werden von unsichtbaren und Bidi-Steuerzeichen bereinigt. Nichts wird automatisch ausgeführt oder an KI weitergegeben.
Sichtbarkeit	Präsenz ist je Gruppe ausdrücklich einzuschalten. Der Modus „nur über Relay“ verbirgt die eigene IP-Adresse vor anderen Mitgliedern.

Der optionale „UdK-Ausweis“: authentik ohne zentralen Datenverkehr

authentik muss nicht im Datenverkehr stehen. Ein kleiner **Ausweis-Dienst** genügt:

1. Man meldet sich einmal per authentik an (OIDC).
2. Der Dienst stellt eine signierte Bestätigung aus: „Gerät mit Schlüssel X gehört zu Name Y, Gruppen Z, gültig bis …“.

3. Andere Teilnehmende prüfen diese Bestätigung **offline** mit dem öffentlichen Schlüssel der UdK. Er ist in der App fest hinterlegt.

Das Ergebnis ist das Abzeichen `UdK-Ausweis` . Kurse können verlangen, dass alle Mitglieder einen gültigen Ausweis haben. Für freie Projekte ist er nur ein Vertrauenssignal.

> **Ehrliche Grenzen**
>
> - **Offline-Zustellung:** Ohne Postfach erreicht eine Nachricht nur Personen, die gerade online sind. Für Tutorials ist das meist unproblematisch, für Projekte sinnvoll ergänzbar.
> - **Mehrere Geräte:** Jedes Gerät ist ein eigenes Mitglied. Ein zweiter Rechner wird wie eine neue Person eingeladen und dem eigenen Profil zugeordnet.
> - **Kopien bei anderen:** Was einmal empfangen wurde, liegt beim Gegenüber. Keine Technik kann es dort zuverlässig löschen (siehe Kap. 8).
> - **Prüfung:** Kryptografische Bausteine nur aus geprüften Bibliotheken übernehmen (OpenMLS, iroh/rustls), nichts selbst erfinden. Vor dem Lehreinsatz ein unabhängiges Review einplanen.

7 Gruppen, Rollen und Gäste

Es gibt drei Arten von Gruppen. Sie unterscheiden sich darin, wer sie anlegt und wie man hineinkommt.

Art	Wer legt an	Wie kommt man hinein	Typischer Einsatz
Kurs	Admins in authentik oder Lehrende in der App	Automatisch über die authentik-Gruppe (Ausweis) oder per Einladung der Lehrenden	Seminar, Tutorial, Übung
Freies Projekt	Jede Person	Persönliche Einladung; wahlweise dürfen Mitglieder weitere einladen	Projektgruppen, Ausstellungen, Arbeitskreise
Direkt	Zwei Personen	Kontaktanfrage, die angenommen werden muss	Absprachen, Hilfe unter vier Augen

Warum Lehrende Kurse in der App anlegen sollten

Würde jeder Kurs eine authentik-Gruppe brauchen, entstünde Verwaltungsaufwand bei den Admins. Besser trägt authentik nur die Rolle „lehrende"; der Ausweis-Dienst schreibt sie in die Bestätigung. Wer sie besitzt, darf in der App Kurse gründen, leiten und auflösen. Admins können zusätzlich Pflichtkurse über authentik-Gruppen vorgeben.

Rollen in einer Gruppe

- **gründet/leitet:** einladen, entfernen, Tutorial steuern, Prompts an alle.
- **Mitglied:** chatten, teilen, je nach Einstellung einladen.
- **Gast:** wie Mitglied, aber nur in dieser Gruppe, mit Ablaufdatum und sichtbar markiert.

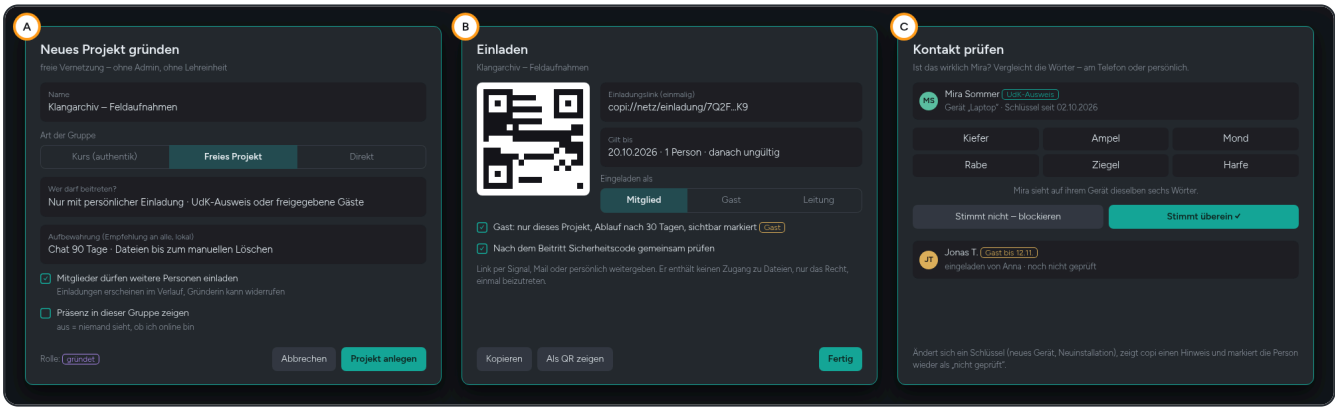


Abb. 2 – (A) Freies Projekt gründen · (B) Einmal-Einladung mit Rolle und Ablauf · (C) Kontakt prüfen mit Sicherheitswörtern; Gäste sind sichtbar markiert (Beispieldaten fiktiv).

Empfehlungen für Gäste

- Gäste nur auf Freigabe einer leitenden Person, mit Einmal-Einladung und Ablaufdatum (Vorschlag: 30 Tage, verlängerbar).
- Gäste sind immer sichtbar markiert, gehören zu genau einer Gruppe und sehen keine anderen Gruppen und keine Mitgliederlisten außerhalb.
- Beim Entfernen eines Gastes wird der Gruppenschlüssel sofort erneuert (MLS).
- Kurse können Gäste grundsätzlich ausschließen; freie Projekte entscheiden selbst.

8 Lokale Speicherung: Risiken und Schutz

„Jede Person speichert lokal nach eigenem Ermessen" ist datensparsam, weil es keinen zentralen Bestand gibt. Die Verantwortung verteilt sich damit aber auf alle Geräte. Diese Risiken sollten bekannt sein:

Risiko	Was passieren kann	Gegenmaßnahme in copi/pi-lite
Verlust oder Diebstahl des Geräts	Chats und Dateien mit Namen, Arbeiten und Fotos anderer fallen in fremde Hände.	Lokaler Speicher verschlüsselt, Schlüssel im System-Schlüsselbund; Festplattenverschlüsselung empfehlen.
Unbemerkte Kopien	Backups, iCloud/Dropbox-Ordner oder Time Machine kopieren Verläufe auf Server Dritter.	Speicherort außerhalb synchronisierter Ordner; Hinweis in den Einstellungen; Export nur bewusst.
Kopien bei anderen	Eine Löschung bei mir löscht nichts bei den anderen. Löschwünsche sind technisch nicht durchsetzbar.	Ablaufzeiten je Gruppe als *Bitte* an alle Apps (automatisches Löschen); klare Kommunikation, dass Geteiltes geteilt ist.
Weitergabe an KI	Jemand übernimmt die Datei oder Nachricht einer anderen Person in seinen Agenten; sie geht damit an einen KI-Anbieter.	Kein automatischer Weg vom Netz zum Agenten; beim Übernehmen Hinweis „stammt von …, wird an Modell X gesendet".
Verhaltensprofile	Präsenz und „Schritt erledigt"-Meldungen zeigen, wer wann wie lange arbeitet; das kann zur Kontrolle missbraucht werden.	Präsenz und Fortschrittsmeldungen opt-in und je Gruppe; keine Historie der Präsenz speichern; keine Auswertungen für Lehrende.
Fremde Inhalte	Dateien mit Schadcode, manipulierte Prompts, Bilder von Personen ohne deren Einverständnis.	Keine Ausführung, Größenlimits, Bereinigung von Steuerzeichen, Melden- und Blockieren-Funktion.
IP-Adressen	Bei direkten P2P-Verbindungen sehen sich Mitglieder gegenseitig die IP-Adresse.	Einstellung „nur über Relay", für Gäste standardmäßig an.

Empfohlene Voreinstellungen

- **Chat:** 90 Tage, danach automatisch löschen (änderbar: nie / 7 / 30 / 90 / 365 Tage).
- **Empfangene Dateien:** bis zum manuellen Löschen, aber getrennt vom Arbeitsordner, in einem eigenen Netz-Ordner.
- **Kurse:** Lehrende können eine Ablaufzeit für den Kurs vorschlagen (z. B. Semesterende). Alle Apps übernehmen sie als Voreinstellung.
- **„Alles von mir löschen“:** eigene Nachrichten bei allen Mitgliedern löschen lassen. Das funktioniert nur kooperativ, nicht erzwungen.

9 Warum Datenschutz trotzdem eine Rolle spielt

Die Frage ist berechtigt: Es handelt sich um ein Lehr-Software-Projekt, Inhalte liegen lokal und sind verschlüsselt. Trotzdem ist der Datenschutz berührt. Der Grund ist nicht die Software, sondern **wessen Daten** darin vorkommen und **in welchem Rahmen** sie genutzt werden.

Die drei Gründe

1 · Es sind Daten anderer Menschen

Namen, Online-Zeiten, Chatinhalte, eingereichte Arbeiten, Fotos: Das alles sind personenbezogene Daten im Sinne der DSGVO, auch wenn sie verschlüsselt und nur lokal liegen.

2 · Es ist Lehrbetrieb

Die DSGVO nimmt nur rein private oder familiäre Tätigkeiten aus. Ein Kurs der Hochschule, mit Teilnehmenden, die sich womöglich zur Nutzung verpflichtet fühlen, ist das nicht.

3 · UdK-Infrastruktur ist beteiligt

Läuft die Anmeldung über authentik und betreibt die UdK Relay und Ausweis-Dienst, verarbeitet die Hochschule selbst Daten (Konten, Gruppen, IP-Adressen). Dafür ist sie verantwortlich.

Was dabei gut ist

Das empfohlene Design hält den Aufwand klein:

- Es gibt keinen zentralen Inhaltsspeicher.
- Server sehen nur verschlüsselte Pakete.
- Präsenz ist opt-in.
- Es gibt keine Auswertungsfunktionen.

Datenschutz bedeutet hier deshalb kein langes Verfahren, sondern wenige konkrete Schritte.

Der kleinste sinnvolle Schritt

1. Kurzes Gespräch mit der behördlichen Datenschutzbeauftragten der UdK, mit dieser Konzeptbeschreibung als Grundlage.
2. Eintrag für den Ausweis-Dienst und das Relay im Verzeichnis der Verarbeitungstätigkeiten.
3. Eine Seite Datenschutzhinweis in der App: was wo liegt, wer was sieht, wie man löscht.
4. **Freiwilligkeit** im Kurs sicherstellen: Wer das Netz nicht nutzen möchte, darf keinen Nachteil haben.
5. Wenn Lehrende mit Beschäftigten-Daten arbeiten (z. B. Fortschritts- oder Präsenzmeldungen): klären, ob die Personalvertretung einzubinden ist.

Hinweis

Dieses Kapitel ist eine fachliche Einordnung, keine Rechtsberatung. Ob etwa eine Datenschutz-Folgenabschätzung nötig ist, entscheidet die UdK; bei diesem sparsamen Design ist das eher unwahrscheinlich. Ein frühes Gespräch kostet wenig und vermeidet spätere Umbauten.

10 Empfehlung und Fahrplan

Empfohlen wird **Variante C**: ein P2P-Kern in Rust (`pi-net`), eingebaut in copi und pi-lite, dazu zwei kleine eigene Dienste – iroh-Relay und Ausweis-Dienst. Später kann optional ein Postfach für Offline-Nachrichten dazukommen.

Phase	Inhalt	Ergebnis und Prüfkriterium
0 · Klären	Entscheidung für C; Gespräch mit der Datenschutzbeauftragten; Domain und Server für Relay und Ausweis-Dienst; authentik-Rolle „lehrende“.	Schriftliche Entscheidung; Testserver erreichbar.
1 · Kern	`pi-net`: Geräteschlüssel, Einladungen, Sicherheitswörter, direkte Gespräche, Präsenz. UI: Netz-Chip, Region, Personenliste in beiden Apps.	Zwei Geräte im LAN und über das Relay; automatisierte Tests mit simulierten Teilnehmenden; Paritätstest copi ↔ pi-lite.
2 · Gruppen	MLS-Gruppen, freie Projekte, Rollen, Gäste mit Ablaufdatum, Entfernen mit Schlüsselerneuerung.	Entfernte Person kann neue Nachrichten nachweislich nicht lesen.
3 · Austausch	Karten für Datei, Codeblock und Prompt; „Ins Netz teilen“; Prompt-Übergabe über der Eingabe; lokale Speicherung mit Ablauf.	Nichts wird automatisch ausgeführt oder gesendet (Testfälle mit präparierten Inhalten).
4 · Lehre	Ausweis-Dienst (authentik), Kurse durch Lehrende, Tutorial-Leiste mit Schritten, „Hand heben“.	Probelauf mit einer kleinen Gruppe; Rückmeldungen zur Bedienung.
5 · Ausbau	Optionales Postfach; Nur-Lese-Freigabe der eigenen Sitzung; unabhängiges Sicherheitsreview.	Review abgeschlossen, Befunde behoben.

Was serverseitig bleibt

- **iroh-Relay:** leitet weiter, speichert nichts.
- **Ausweis-Dienst:** etwa eine Seite Code; signiert Bestätigungen, speichert höchstens ein Protokoll.
- **Optional ein Postfach** mit kurzer Aufbewahrung.

Alle drei lassen sich als einzelne Programme betreiben, ohne Datenbankserver.

Wann doch Matrix?

- wenn Nachrichten zuverlässig auch tagelang offline zugestellt werden müssen,
- wenn viele Personen mit mehreren Geräten arbeiten,
- wenn ein fertiger Ersatz-Client (Element) für Nicht-copi-Nutzende wichtig ist.

Das UI bleibt gleich. Nur `pi-net` würde intern auf Matrix wechseln.

11 Checkliste zum Abhaken

Entscheidungen

- ☐ Architektur C (P2P iroh + MLS) bestätigt
- ☐ Server/Domain für Relay und Ausweis-Dienst festgelegt
- ☐ authentik-Rolle „lehrende“ angelegt, Ausweis-Dienst als OIDC-Anwendung
- ☐ Gastregeln: Ablauf 30 Tage, nur auf Freigabe, nur eine Gruppe
- ☐ Voreinstellung der Aufbewahrung: Chat 90 Tage

Datenschutz

- ☐ Gespräch mit der Datenschutzbeauftragten der UdK geführt
- ☐ Eintrag im Verzeichnis der Verarbeitungstätigkeiten
- ☐ Datenschutzhinweis in der App
- ☐ Freiwilligkeit im Kurs zugesichert
- ☐ Personalvertretung geklärt, falls Beschäftigte betroffen

Sicherheit (Abnahme)

- ☐ Geräteschlüssel nur im System-Schlüsselbund
- ☐ Einmal-Einladungen mit Ablauf und Widerruf
- ☐ Sicherheitswörter und Warnung bei Schlüsselwechsel
- ☐ Schlüsselerneuerung nach jedem Entfernen nachgewiesen
- ☐ Prompts und Code nie automatisch gesendet oder ausgeführt
- ☐ Dateien ohne Ausführungsrecht, mit Größenlimit und Prüfsumme
- ☐ „Nur über Relay“ verfügbar, für Gäste voreingestellt
- ☐ Lokaler Speicher verschlüsselt, außerhalb von Sync-Ordnern
- ☐ Parität copi ↔ pi-lite getestet
- ☐ Unabhängiges Review vor breitem Lehreinsatz

A Begriffe und Bausteine

Begriff	Bedeutung
authentik	Identitätsanbieter der UdK (`auth.udk.digital`); verwaltet Konten, Gruppen und Rollen, Anmeldung per OIDC.
OIDC	OpenID Connect – Standard für „Mit … anmelden“; liefert der App eine geprüfte Identität.
iroh	Rust-Bibliothek für direkte, verschlüsselte Verbindungen zwischen Geräten (QUIC), mit Relay als Ausweichweg; Zusatzmodule für Gruppen-Nachrichten (gossip) und Dateien (blobs).
MLS / OpenMLS	IETF-Standard (RFC 9420) für Ende-zu-Ende-verschlüsselte Gruppen; OpenMLS ist die Rust-Umsetzung.
Relay	Weiterleitungsserver für verschlüsselte Pakete, wenn keine Direktverbindung möglich ist.
Ausweis-Dienst	Kleiner eigener Dienst: nach authentik-Anmeldung signierte Bestätigung „Geräteschlüssel X = UdK-Person Y, Rollen Z“.
Postfach	Optionaler Dienst, der verschlüsselte Nachrichten für Offline-Personen kurz aufbewahrt.
Matrix / Headscale	Alternativen: föderierbares Chatprotokoll mit eigenem Server bzw. selbst betriebener Steuerserver für ein WireGuard-VPN.

Hinweise zu Produkten und Bibliotheken geben den allgemeinen Kenntnisstand wieder. Vor der Umsetzung sind aktuelle Versionen, Lizenzen und der Wartungsstand zu prüfen.